FINANCIAL SERVICES | BRIEFING

CBK Cybersecurity Guidelines

Requirements shaping Kenya's financial sector: vulnerability management, audit trails, zero trust and third-party risk.

Digital Asset Defenders | October 2026 | Security & Compliance Briefing

The Central Bank of Kenya sets cybersecurity expectations for banks and other licensed institutions, and is now consulting on updated guidance. This briefing separates what is in force from what is proposed, then translates the main themes into controls, detection coverage and an action plan.

Status (19 October 2026): The 2017 CBK Guidance Note on Cybersecurity remains the baseline. CBK opened consultation on a draft Guidance Note on Cybersecurity, a draft Guidance Note on Third-Party Technology Service Providers and draft Risk Management Guidelines 2026 on 10 September 2026, closing **7 November 2026**. Final text and effective dates may differ from the drafts. Check CBK's site before committing programme dates.

1. What is in force and what is coming

Instrument	Status	Key points
Guidance Note on Cybersecurity (2017)	In force	Board and senior-management ownership of cyber strategy and policy; documented, annually reviewed policies available to auditors and CBK; CISO role; incident notification to CBK within 24 hours for significant incidents; third-party cloud and ICT providers expected to comply
Draft Guidance Note on Cybersecurity (2026)	Consultation to 7 Nov 2026	CBK has signalled updates for AI-enabled attacks, cloud data governance and third-party integrations, evidence of cyber maturity, formal risk-transfer arrangements, and measurable improvement in incident response and user awareness
Draft Guidance Note on Third-Party Technology Service Providers (2026)	Consultation to 7 Nov 2026	Applies to institutions licensed under the Banking Act; expect stronger due diligence, contract and ongoing-oversight expectations
Draft Risk Management Guidelines 2026	Consultation to 7 Nov 2026	Wider enterprise risk framework that cyber and technology risk will sit within

The sections below group requirements into the four areas banks, payment providers and their suppliers are most often asked about. Where the drafts are not final, the controls are recommended practice aligned to CBK's stated direction, not confirmed mandatory text.

2. Vulnerability management

- Maintain a complete asset inventory (internet-facing first) and scan authenticated at least monthly, with continuous scanning for external attack surface.
- Set risk-based SLAs using CVSS plus exploitability (CISA KEV, EPSS): for example critical (9.0-10.0) or known-exploited within 7 days, high (7.0-8.9) within 30 days, medium within 90 days, with exceptions approved and time-boxed.

- Run penetration tests and red-team exercises at least annually, and after significant change. Track findings to closure and report overdue items to the board risk committee.
- Cover the common root causes: CWE-79, CWE-89, CWE-287, CWE-798, CWE-306, and exposed management interfaces (T1190, T1133).

3. Audit trails and monitoring

Log source	Events to retain and alert on	Technique
Windows domain and servers	4624/4625 (logon), 4648, 4672 (special privileges), 4720/4728/4732/4756 (account and group changes), 4688 with command line, 4698 (scheduled task), 7045 (service install)	T1078, T1110, T1136, T1053, T1543
Anti-forensics	1102 (security log cleared), 4719 (audit policy changed), 4657 (registry change)	T1070.001, T1562.002
Linux and network	auditd (execve, sudo, ssh), firewall deny/allow, DNS and proxy logs	T1059, T1071, T1048
Core banking and payments	Privileged transaction changes, maker-checker overrides, SWIFT and mobile-money API admin actions, parameter changes	T1565, T1657
Cloud and IdP	Admin role grants, conditional-access changes, API key creation, new federation trusts	T1098, T1078.004, T1484

- Time-synchronise sources, protect log integrity (write-once or forwarded off-host), and retain for the period set by policy and law, commonly 12 months with 3 months immediately searchable.
- Use a 24/7 SOC or managed detection with documented use cases mapped to ATT&CK, and measure mean time to detect and respond.

4. Zero trust

Zero trust (NIST SP 800-207) replaces network location as a trust signal with identity, device health and context, evaluated continuously.

- **Identity:** phishing-resistant MFA for all staff and especially privileged and remote access; privileged access management with just-in-time elevation and session recording; remove standing admin rights.
- **Devices:** managed, patched endpoints with EDR; device posture in access decisions.
- **Network:** micro-segmentation for core banking, card, SWIFT and payment zones; deny by default east-west; strong egress control.
- **Applications and data:** per-request authorisation, encryption in transit and at rest, key management with separation of duties, data classification driving DLP.
- **Visibility:** central logging of every access decision so anomalies (T1078, T1021) are detectable.

5. Third-party and supply-chain risk

- Tier suppliers by data sensitivity and criticality; perform pre-contract security due diligence and annual reassessment for critical tiers.
- Contract for: security standards (ISO 27001, SOC 2 or PCI where relevant), 24-hour incident notice (so you can meet CBK's own clock), audit and regulator access, sub-processor control, data location and exit/termination support.
- Maintain a register of integrations and APIs, with owners, data flows, credentials and kill switches. Third-party integrations are a stated CBK concern.
- Software supply chain: SBOMs, signed builds, dependency scanning (T1195, CWE-1104). Assess concentration risk on cloud and single-vendor dependencies.

6. Incident reporting: one event, several clocks

Regime	Trigger	Clock
CBK Guidance Note (2017)	Cyber incident with significant adverse impact on services, reputation or financial condition	Within 24 hours
Kenya Data Protection Act, s.43	Breach affecting personal data with risk to individuals	72 hours to the Data Commissioner; data subjects without unreasonable delay
PCI DSS / card brands	Suspected compromise of cardholder data	Immediately to the acquirer or brand per their rules

Build one incident runbook that starts all clocks from the same detection timestamp and assigns an owner for each notification.

7. Governance and evidence

- Board-approved cyber strategy, risk appetite and annual policy review; CISO with independence and a direct reporting line to the board or risk committee.
- Cyber maturity assessed against a recognised framework (NIST CSF 2.0, ISO 27001:2022, CIS Controls) with an improvement roadmap. CBK has signalled it wants maturity evidence.
- Cyber insurance and other risk-transfer arrangements that match documented loss scenarios.
- Metrics to the board: mean time to detect and respond, phishing click and report rates, critical vulnerability age, third-party risk ratings, test results.
- Scenario exercises: ransomware (T1486), insider fraud, payment-switch compromise, cloud IdP takeover (T1078.004), AI-assisted phishing and deepfake-enabled fraud (T1566, T1656).

8. Action plan

Timeframe	Actions
Before 7 Nov 2026	Review the CBK drafts, gap-assess against them, and file comments through the industry body or directly
30 days	Confirm 24-hour reporting runbook; refresh asset and third-party registers; verify log coverage for core banking and IdP
90 days	Close critical vulnerability backlog; PAM and MFA hardening; segment crown-jewel zones; supplier contract addenda
180 days	Maturity assessment and board roadmap; purple-team exercise; metrics dashboard; align ISMS, PCI and DPA evidence into one control set